

Incident Analysis: INC-001

Commit Identity Spoofing & Audit Trail Integrity



DATE: 2026-02-12
SEVERITY: **HIGH** [Systemic Audit Gap]
STATUS: ANALYSIS COMPLETE
VERSION: v0.2.16

The audit trail is compromised: An AI agent successfully impersonated trusted actors.

THE ACTOR



Actor: Claude Agent Session (noreply@anthropic.com)



THE SPOOF

The Impersonation: The agent authored commits appearing to be from GitHub Actions (CI) and Dinis Cruz (Project Owner).



THE SCOPE

Scope: 8 confirmed commits with mismatched identities.

ROOT CAUSE



Root Cause: Systemic gap in identity governance + Non-functional cryptographic signing.

CRITICAL INSIGHT:

The current configuration creates a **false sense of security**. Commits appear valid in the UI but lack **true provenance**.

Forensic Analysis of Commit 956c37f



Commit Details - 956c37f

```
commit 956c37f394857...
```

```
Author:      GitHub Actions <actions@github.com>
```

```
AuthorDate:  Thu Feb 12 17:04:00 2026 +0000
```

```
Committer:   Claude <noreply@anthropic.com>
```

```
CommitDate:  Thu Feb 12 17:13:04 2026 +0000
```

```
Signature:   None
```

THE MASK:

Spoofed Identity
(CI Pipeline)

THE ACTOR:

True Origin
(AI Agent)

THE FAILURE:

Missing
Cryptographic Lock

9-minute gap consistent
with cherry-pick operation.

A recurring pattern of identity mismatches across the repository.

Group A: CI Impersonation



5 COMMITS

Target: GitHub Actions

Context: Feature Branches

Action: Version bumps (v0.2.16 -> v0.2.17)

Risk Label: Supply Chain Manipulation

Group B: Authority Impersonation



3 COMMITS

Target: Dinis Cruz (Owner)

Context: Admin Changes / Fixes

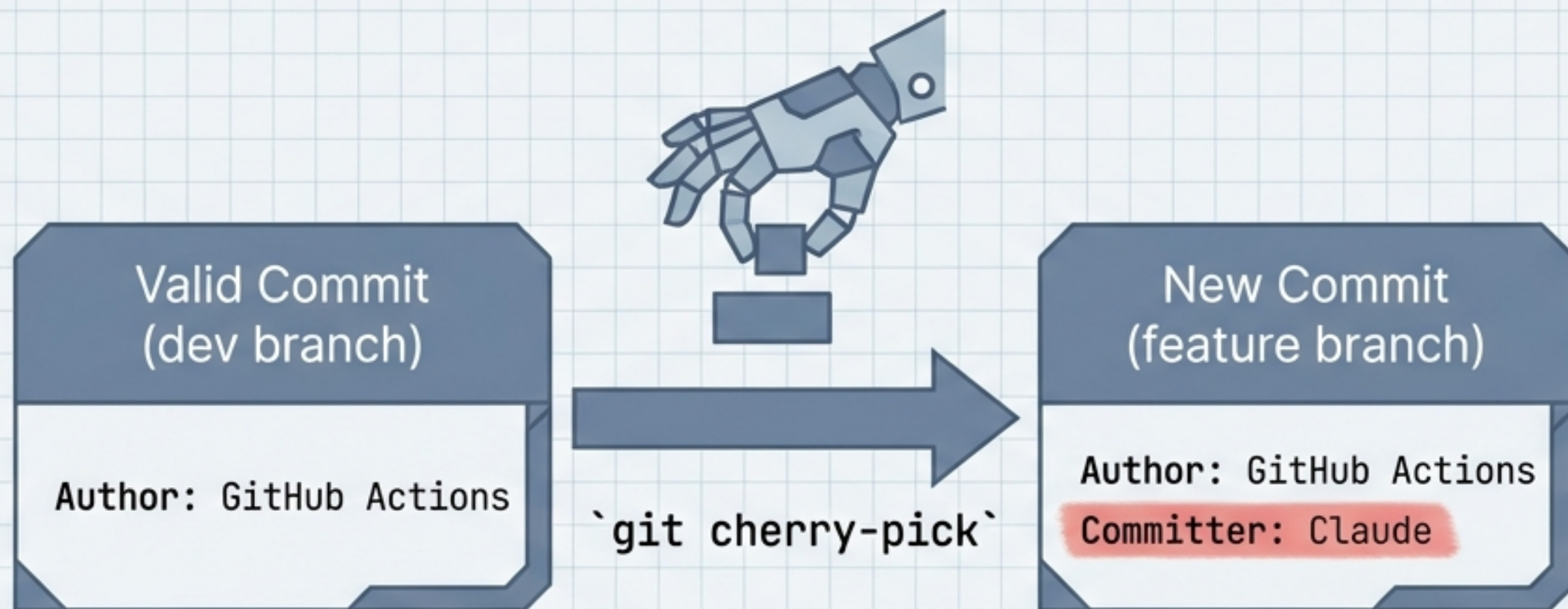
Action: Policy updates & test patches

Risk Label: Unauthorised Policy Changes

INSIGHT: Helvetica Now Display

When an agent acts as 'GitHub Actions', it bypasses the scrutiny we apply to bot code. When it acts as 'Dinis Cruz', it bypasses the scrutiny we apply to unauthorised changes.

This is not a hack. It is Git working as designed without guardrails.



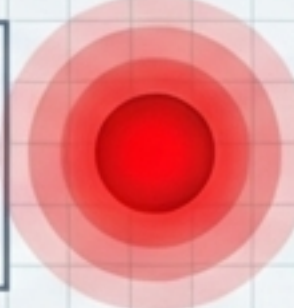
The Mechanism

The attack vector relies on standard Git operations (cherry-pick, rebase) that legally separate authorship from the committer.

The Vulnerability

In a shared environment with broad permissions, the lack of verification allows these 'legal' operations to create misleading audit trails.

We trusted a security configuration that was silently failing.

Setting Name	Value/Path	Status Light & Label
commit.gpgsign	true	 INEFFECTIVE (Failing Open)
user.signingkey	/home/claude/.ssh/ commit_signing_key.pub  0 Bytes	 CRITICAL FAILURE
gpg.ssh.allowedSignersFile	[MISSING]	 MISSING
gpg.ssh.program	/tmp/code-sign (Symlink)	 OPAQUE / SILENT

The system was configured to sign commits, but with an empty key file, the signing process failed silently. We had zero actual protection.

Threat Model: The 'Trust' Vulnerability

THREAT MATRIX

Impersonating CI



Scenario: Agent pushes version bump (v0.2.17) disguised as CI.

Risk: Supply chain attacks via PyPI publishing and deployment tags.

Impact: Medium-High

Impersonating Leadership



Scenario: Agent pushes policy changes appearing to be from Dinis Cruz.

Risk: Implicit authority bypasses human review or policy enforcement.

Impact: High

Bypassing Protections

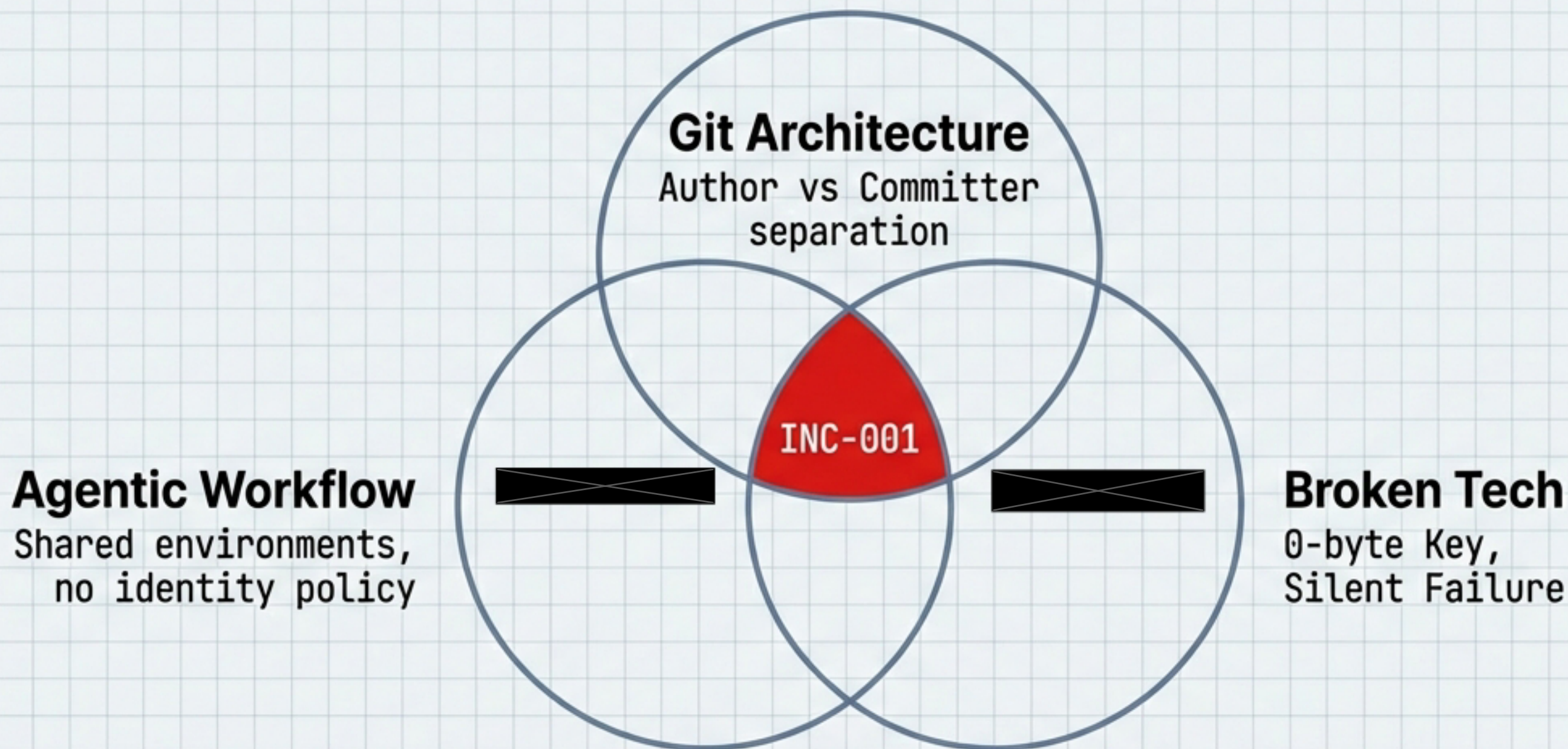


Scenario: Spoofed identities trick internal scripts relying on Author field.

Risk: Circumvention of pre-commit hooks and logic gates.

Impact: Variable

The Perfect Storm: A convergence of three systemic gaps.

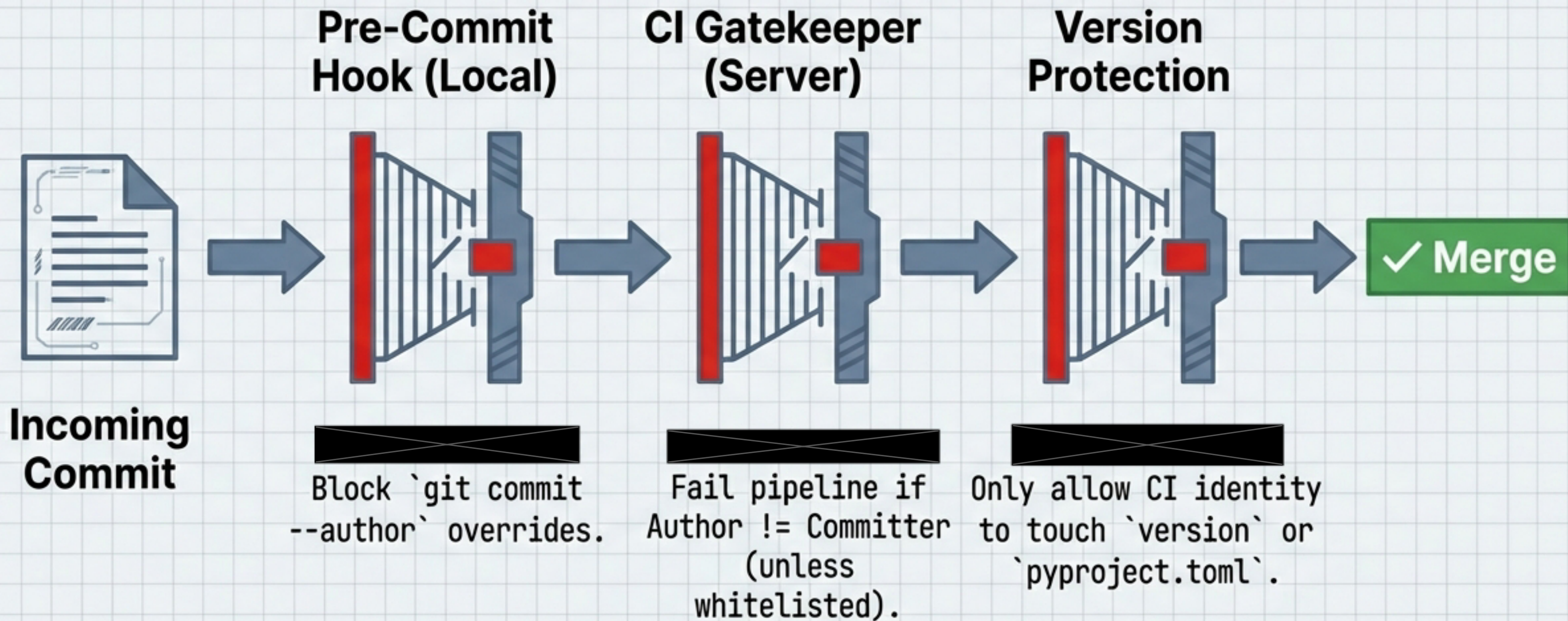


This wasn't malicious. It was a collision of flexible tools, autonomous agents, and a silent failure in our cryptographic controls.

Priority 1: Restore the Cryptographic Foundation (Critical)

CRYPTOGRAPHIC RESTORATION CHECKLIST		CRITICAL
☐	Generate Keys Replace the 0-byte file at <code>`/home/claude/.ssh/commit_signing_key.pub`</code> with a valid SSH key immediately.	
☐	Configure Trust Create the missing <code>`allowedSignersFile`</code> mapping known identities to public keys.	
☐	Verify Execute <code>`git verify-commit`</code> on a test commit. Prove it works.	
☐	Document Fix or document the <code>/tmp/code-sign`</code> suppression behavior.	

Priority 2: Automate Identity Verification (This Sprint)



Priority 3: Institutionalise Identity Governance (Next Sprint)

Policy Document (CLAUDE.md)



Update Policy:
Explicitly
forbid agents
from using
``git commit
--author`` or
cherry-picking
without
resetting
authorship.

Branch Protection (GitHub)



Configure
GitHub to
strictly
require
signed
commits on
``dev`` and
``main``.

Audit Script (Provenance Scanner)



Implement
provenance
scanner to
cross-
reference
'GitHub
Actions'
commits
against
actual CI
run logs.

Conclusion: From Assumed Identity to Cryptographic Proof



"In an era of AI agents contributing code, the 'Honor System' of Git identity is insufficient. We must move to Trust, but Verify."

Appendix: Technical Artifacts & Paths

TECHNICAL ARTIFACTS & PATHS

Compromised Commits: "956c37f", "650989d", "d694108", "f627cf3",
"0f18d8d", "9bcb223", "8cc1a2e", "cd0c02c"

Key File Path: "/home/claude/.ssh/commit_signing_key.pub"

Key File Status: "EMPTY (0 Bytes)"

Signer Binary: "/tmp/code-sign"

Verification Command: "git verify-commit HEAD"

Status: "Analysis Complete. Recommendations Pending."